

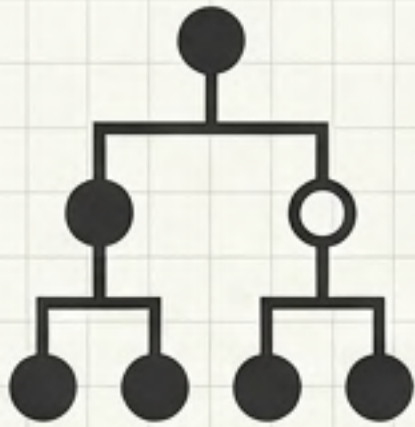
# Lección 08: Análisis Forense de Red

De la **captura** de paquetes a la construcción de inferencias.

## Forense de Sistema Operativo - Lección 07



DISCO DURO



ÁRBOL DE  
PROCESOS LÓGICOS



REGISTRO DE  
EVENTOS DE WINDOWS

Lo que el equipo registró (depende de su configuración y reloj).

## Forense de Red - Lección 08



ONDAS DE SEÑAL  
Y CABLEADO



SENSOR EXTERNO  
INDEPENDIENTE

Lo que el sensor registró desde su punto de captura.  
(sensor externo, reloj independiente).

Ambos mundos se complementan. Los principios de **integridad**, **copias de trabajo read-only** y **verificación mediante SHA-256** aplican idénticamente para un disco duro que para un archivo **PCAP**.

# El alcance de la red:

## Hechos observables vs. Límites de evidencia

### La red DEMUESTRA (Hechos Observables)

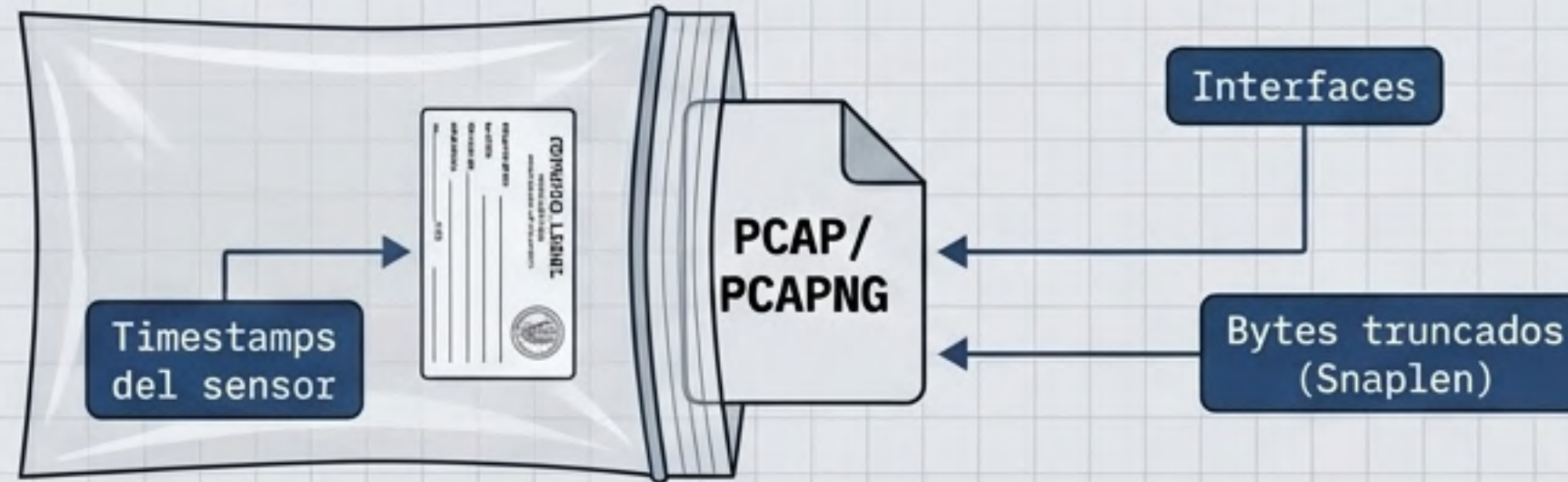
- ✓ Paquetes observados entre direcciones IP.
- ✓ Puertos de origen y destino utilizados.
- ✓ Cantidad de *bytes* capturados en cada sentido.
- ✓ *Timestamps* registrados por el reloj del sensor.
- ✓ Nombres de dominio consultados mediante DNS.

### La red NO DEMUESTRA por sí sola (Límites y Puntos Ciegos)

- ✗ La identidad de la persona física frente al teclado.
- ✗ El programa o proceso exacto que inició la conexión (el *User-Agent* es solo texto declarativo).
- ✗ Si un archivo descargado se ejecutó finalmente en el sistema local.
- ✗ Tráfico perdido si el punto de captura (ej. puerto SPAN) se saturó.

# Anatomía de la Evidencia: El PCAP y la 5-Tupla

## El Contenedor



**PCAP/PCAPNG:** archivo que conserva los paquetes registrados por el sensor. Su integridad debe verificarse.

⚠ **Nota:** Si la captura es parcial, lo que no está no significa que no existió, solo que no se capturó.

## La Identidad de la Conexión



El puerto orienta sobre el servicio esperado, pero no garantiza qué protocolo realmente circula.

**Paquete** → **Flujo** → **Conversación** → **Sesión**  
(1 unidad) (1 dirección) (2 direcciones) (Intercambio lógico completo)

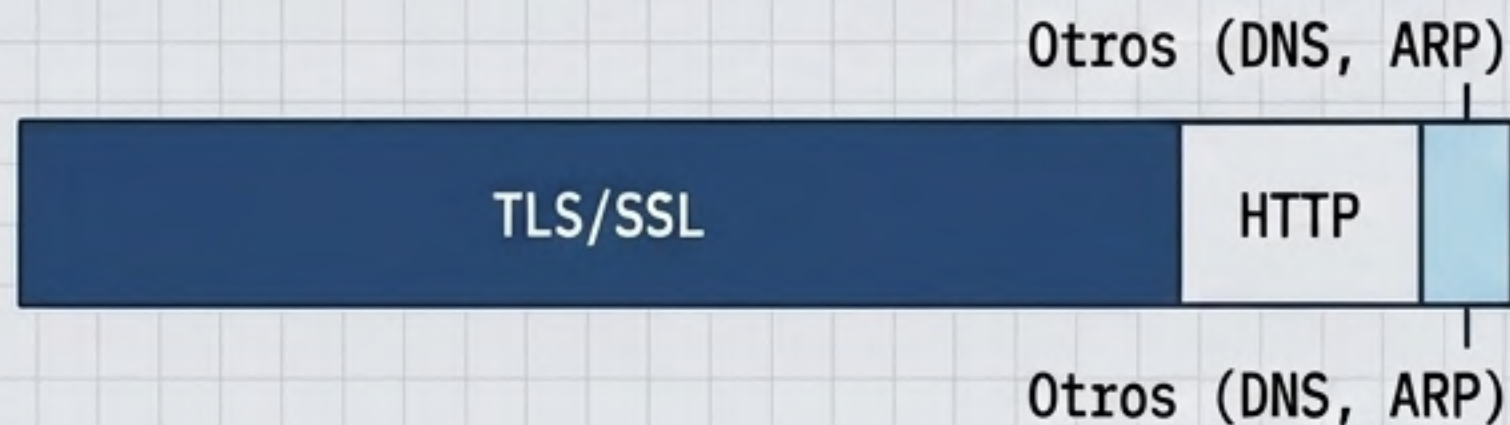
# Regla de Oro: El panorama general precede al detalle

No busques malware a ciegas. Primero, caracteriza tu evidencia para establecer la línea base normal.

## Cronología (Ventana de Tiempo)



## Jerarquía de Protocolos



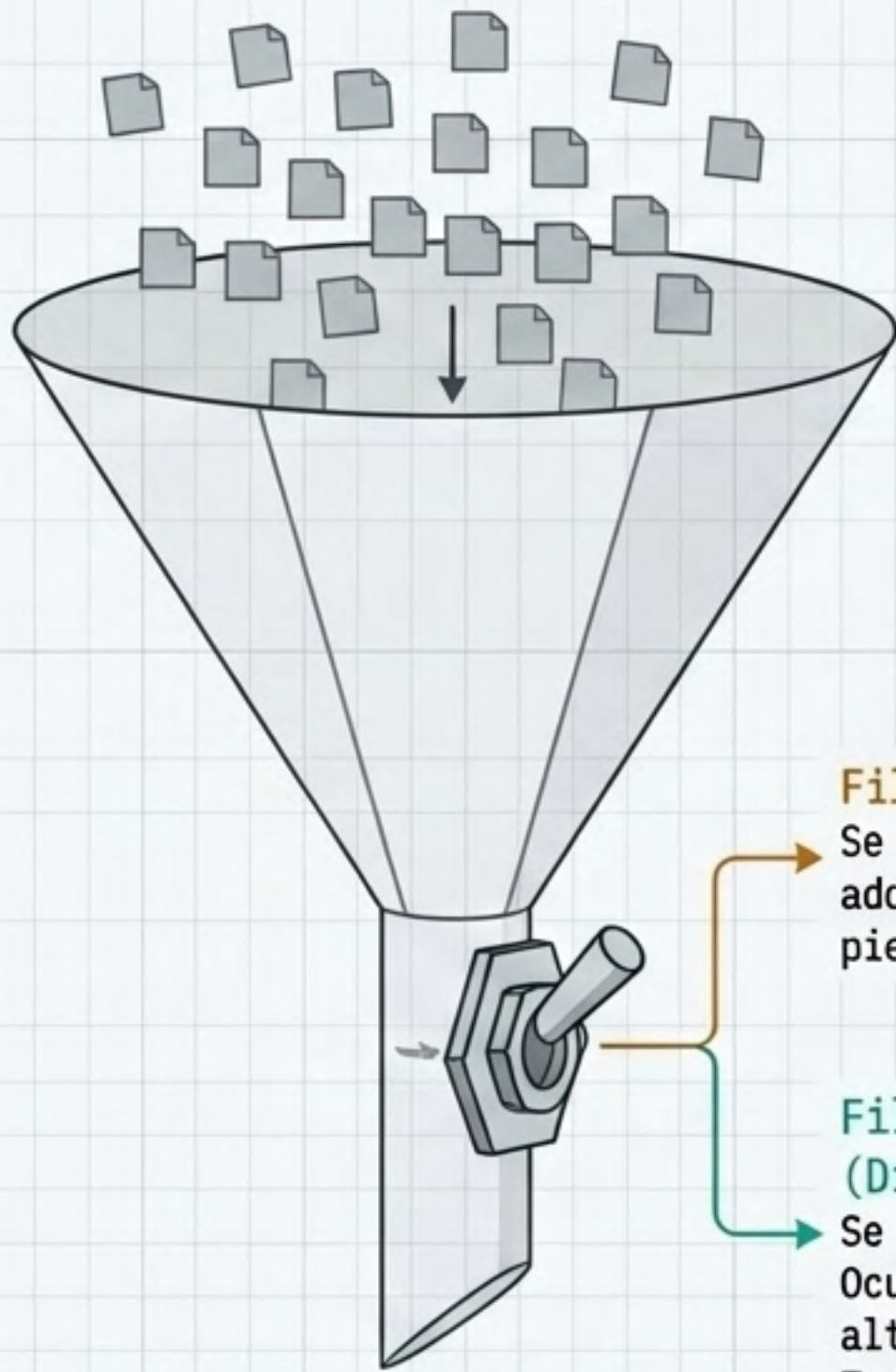
¿Qué protocolos dominan? Evita buscar tráfico HTTP en claro si el 99% de la captura es TLS.

## Conversaciones y Endpoints



¿Quiénes hablan más? Identificar la IP investigada vs. otras IP según el contexto de la red y medir el volumen de paquetes. Ayuda a distinguir tráfico de fondo automatizado.

# El Bisturí del Analista: Filtrado Forense



## Filtros de Captura (BPF):

Se aplican durante la adquisición. Lo descartado se pierde para siempre.

## Filtros de Visualización (Display Filters):

Se aplican sobre el archivo PCAP. Ocultan tráfico en pantalla sin alterar la evidencia original. Todo hallazgo forense se sustenta en un filtro reproducible.

## Ejemplos de Sintaxis (Display Filters)

```
ip.addr == 10.0.0.5
```

(Todo tráfico de una IP)

```
dns.flags.response == 1
```

(Solo respuestas DNS)

```
tcp.stream eq 0
```

(Aísla una sesión completa)

```
http.request
```

(Solo solicitudes web)

```
tls.handshake.type == 1
```

(Inicios de cifrado - ClientHello)

```
dns.flags.response == 1 &&  
ip.dst == <IP>
```

(Solo respuestas DNS dirigidas al equipo investigado)

```
http.response.code >= 400
```

(Respuestas HTTP con error)

```
tls.handshake.type == 1 &&  
ip.src == <IP>
```

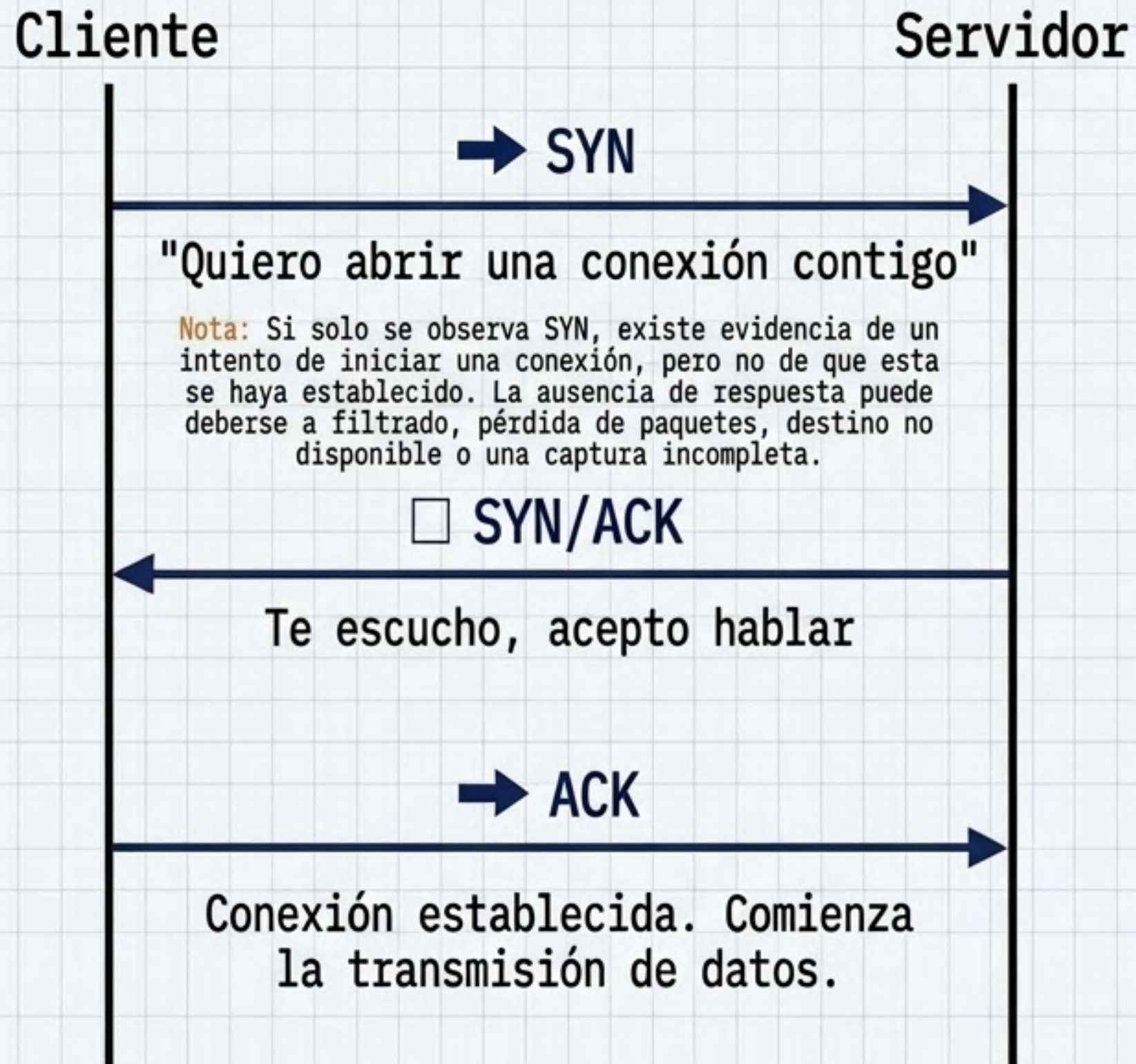
(Client Hello enviados por el equipo investigado)

# Paso 1: DNS (La Brújula de la Conexión)



- **Hecho Observable:** El equipo solicitó conocer la IP de un dominio.
- **Límite Forense / Precaución:** Resolver un nombre NO es establecer una conexión. Solo demuestra una intención (o un proceso automatizado en segundo plano). Debes buscar el paquete TCP siguiente para confirmar el contacto real.

## Paso 2: TCP (Estableciendo la Comunicación)



### El Índice Lógico (tcp.stream)

Herramientas como Wireshark/TShark agrupan todos los paquetes de esta conversación bajo un número (ej. `tcp.stream eq 0`).

**⚠ Precaución:** Este número NO viaja por el cable de red; es una etiqueta generada por la herramienta para facilitar tu análisis. Al documentar, acompáñalo siempre con la **5-tupla**.

# Paso 3: HTTP (Reconstruyendo la Transferencia)

| Estructura de la Solicitud<br>(Cliente → Servidor)                                                                                                                                                                                      | Estructura de la Respuesta<br>(Servidor → Cliente)                                                                                                                                                                                                                                                                                                                        |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Método:</b><br/>GET (pedir) o POST (enviar).</p> <p><b>URI:</b><br/>El recurso exacto o ruta solicitada.</p> <p><b>Host:</b><br/>El dominio al que se dirige.</p> <p><b>User-Agent:</b><br/>Declaración del software cliente.</p> | <p><b>Código de Estado:</b><br/>200 OK (Éxito), 404 (No encontrado).</p> <p><b>Content-Type:</b></p> <p><b>Content-Disposition:</b><br/>Puede indicar cómo debe presentarse el contenido y sugerir un nombre de archivo.<br/>Ejemplo: attachment; filename="archivo.zip"</p> <p><b>Content-Length:</b><br/>Tamaño declarado del cuerpo de la respuesta HTTP en bytes.</p> |

Límite: Es texto plano, fácilmente falsificable por malware

La línea temporal es la prueba lógica: **Solicitud -> Respuesta -> Carga útil transferida.**

Una misma conexión HTTP/1.1 puede transportar varias solicitudes y respuestas.  
Por ello, un mismo tcp.stream puede contener más de un intercambio.

# Protocolo de Extracción Controlada de Objetos

## Paso 1: Aislar



Exportar los objetos HTTP siempre a una carpeta de trabajo separada.

**NUNCA** sobrescribir la ruta de la evidencia original (read-only).

## Paso 2: Trazar



Registrar de qué número de paquete y respuesta exacta proviene el objeto extraído.

## Paso 3: Verificar



Calcular el SHA-256 inmediatamente.

Contrastar el tamaño real del archivo en disco con el Content-Length declarado en la captura.

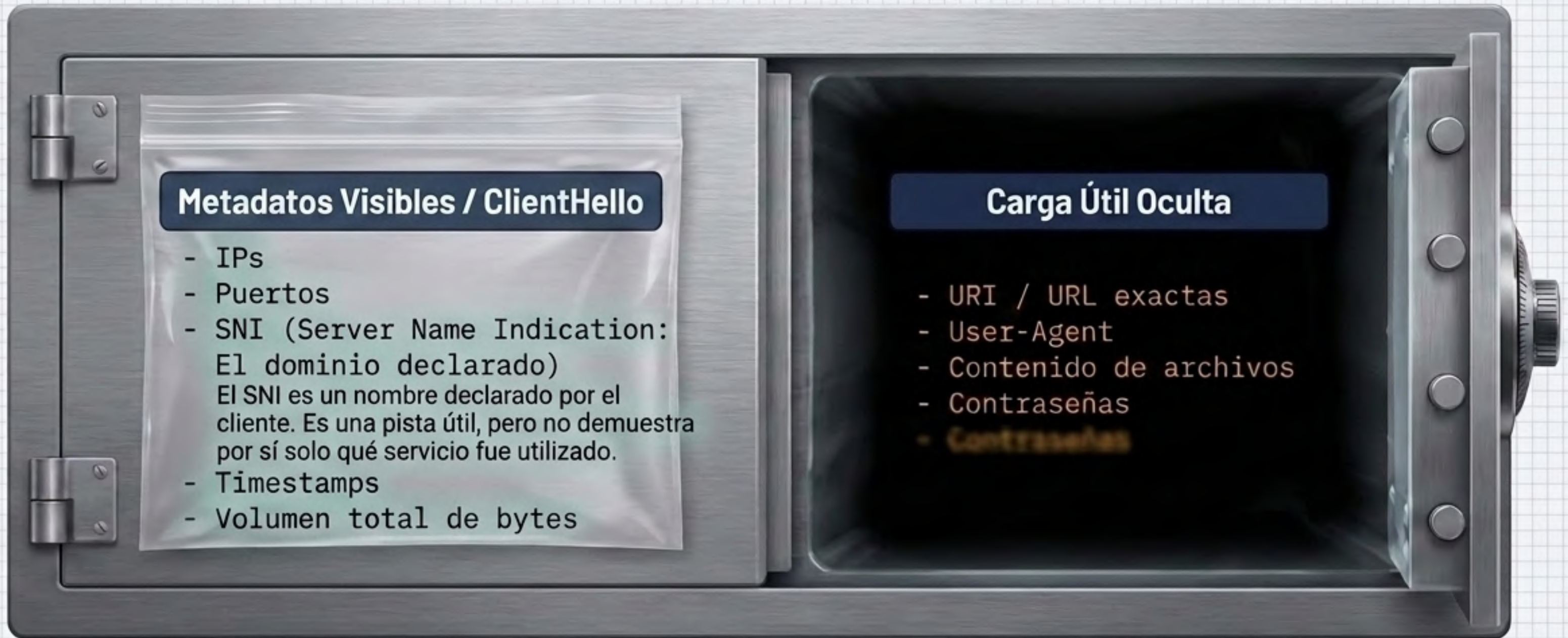
## Paso 4: Prohibición Absoluta



**NUNCA** abrir el archivo con aplicaciones asociadas (PDF, Word) ni ejecutarlo en el sistema anfitrión. Un objeto de red puede contener código malicioso.

Si es necesario inspeccionar contenido, hacerlo desde la captura mediante Follow TCP Stream o con herramientas seguras que no ejecuten el objeto.

## Paso 4: TLS (La Perspectiva Forense Cifrada)

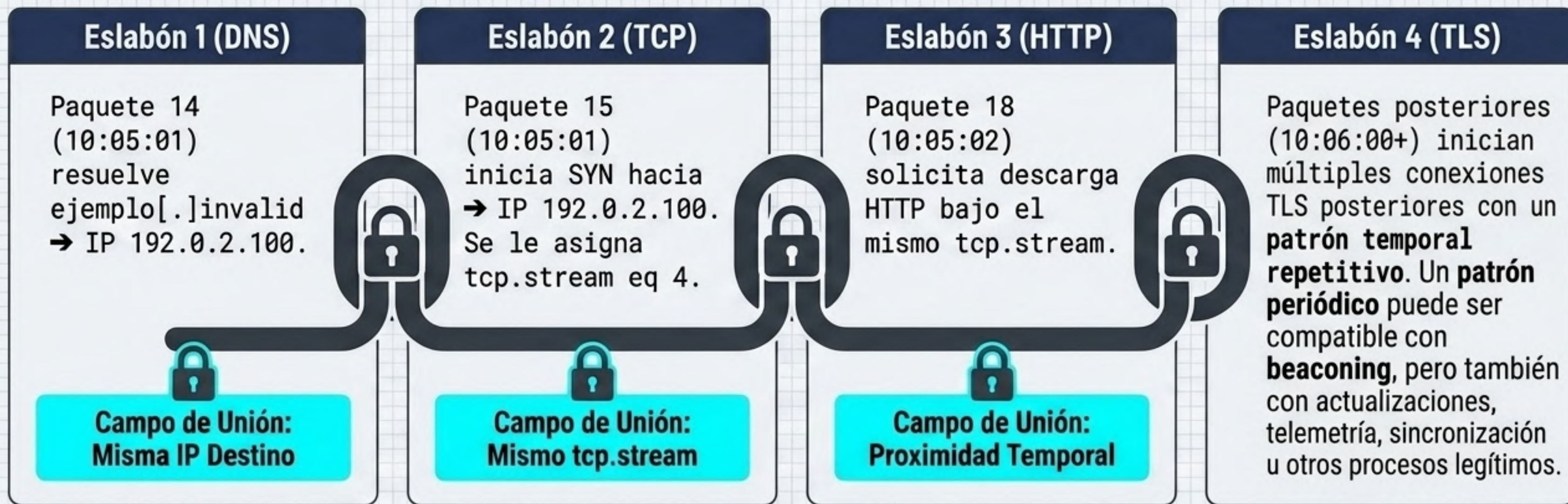


### Inferencia Prudente



En TLS sobre TCP, el handshake TLS comienza después de establecer la conexión TCP. **NO** puedes inferir 'robo de datos confidenciales' únicamente observando tráfico cifrado. La captura permite demostrar **metadatos observables** como **IP, puertos, timestamps**, SNI cuando está visible, **volumen y periodicidad**, pero no el contenido transferido ni su intención.

# Correlación Temporal: Uniendo las Piezas de Evidencia



## Regla de Oro



Para relacionar eventos necesitas **número cronológico**, coincidencia de Timestamps, e **identificadores compartidos** (5-tupla, IP resuelta, tcp.stream).

## Causalidad vs. Correlación



Que el TLS comience justo después de la descarga HTTP es una relación temporal, pero para probar **causalidad absoluta** se requiere cruzar con registros de procesos del SO.

# Indicadores (IoCs), Contexto y Falsos Positivos

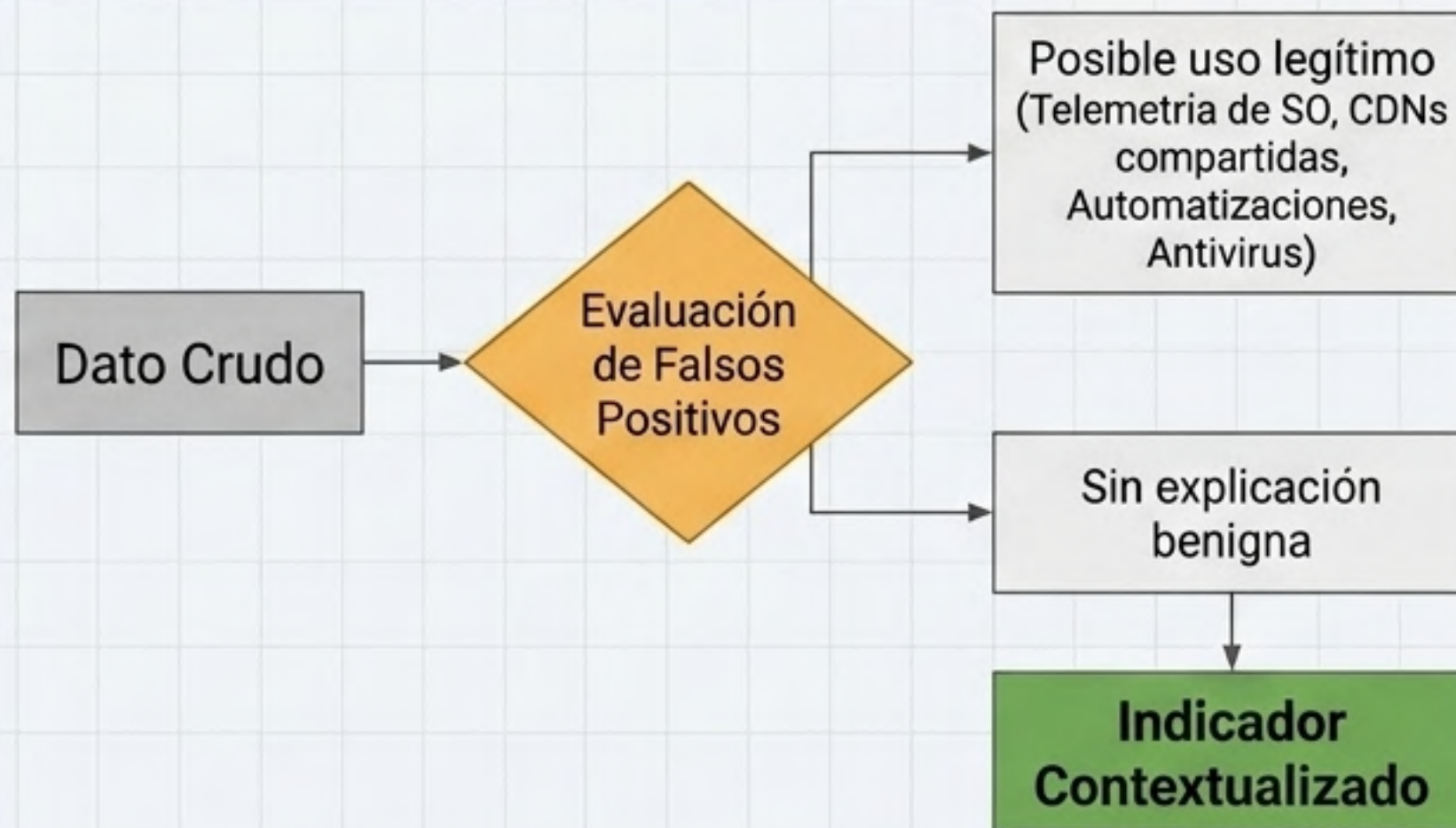
## La Ficha de Evidencia

### ¿Qué es un IoC de red?

- Dominio
- IP
- URL
- Hash
- User-Agent

**\*\*Un dato observable puede considerarse un IoC cuando el contexto permite asociarlo razonablemente con actividad no autorizada.\*\***

## El Filtro Crítico



## Buenas Prácticas (Defanging)

"http://" → "hxxp://"

"malicioso.com" → "malicioso[.]com" o "malicioso[.]invalid"

# La Anatomía de una Inferencia Forense Prudente

Hecho A



Hecho B



Campo de Unión

**Relación:** La respuesta puede relacionarse con la solicitud mediante el mismo tcp.stream, la secuencia temporal y los campos HTTP observados.

## Inferencia con Confianza

Es altamente probable que el equipo haya descargado el archivo X de 4096 bytes en ese instante temporal.

## El Límite / Dato Faltante



**Rigor Profesional:** La red NO indica qué proceso local desencadenó esta solicitud, ni si el archivo descargado fue ejecutado posteriormente por un usuario.

## Explicación alternativa / dato faltante:

¿Qué otra explicación sigue siendo compatible con la evidencia o qué fuente permitiría corroborar la inferencia?

# Buenas Prácticas Operativas: TShark Cheat Sheet

(Read). Analiza una captura existente en modo de solo lectura. Evita generar tráfico nuevo.

Aplica un Display Filter seguro (ej. 'http.request').

Almienta la salida  
fin. ie1 ed "-ipeitc,"

```
tshark -r captura.pcap -n -Y "filtro" -T fields -e campo
```

(No resolve). VITAL EN FORENSE.  
Apaga la resolución local de nombres DNS.  
Evita que el laboratorio genere tráfico hacia el exterior y contamine la captura mezclando nombres de hoy con datos pasados.

Modela la salida seleccionando solo columnas útiles (ej. '-e frame.number -e ip.src').

```
TZ=UTC capinfos -c -a -e -u captura.pcap
```

Cantidad de paquetes, primer paquete, último paquete y duración.

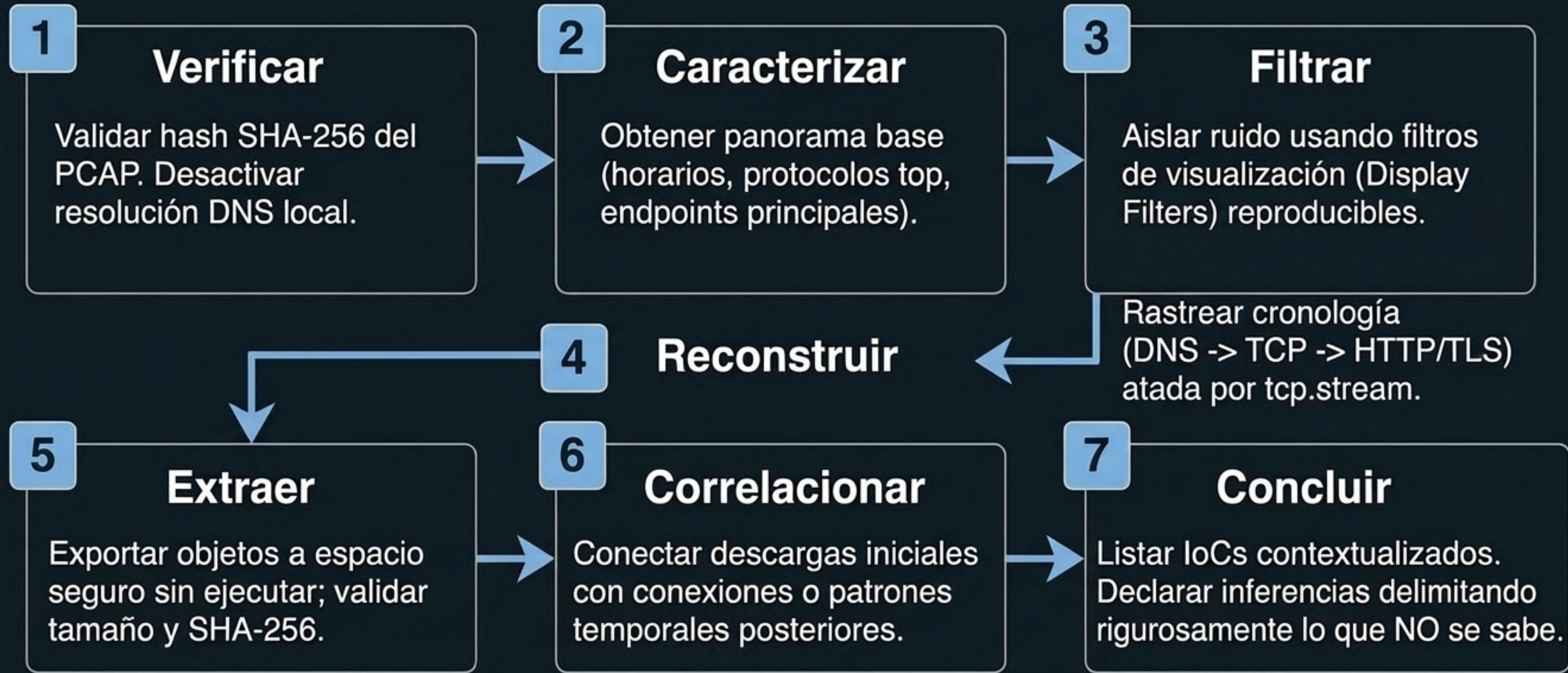
```
tshark -r captura.pcap -n -q -z io,phs
```

Muestra la jerarquía de protocolos.

```
tshark -r captura.pcap -n -q -z conv,ip
```

Muestra las conversaciones IPv4.

# Síntesis: El Flujo Maestro del Análisis de Red



**Rigor Profesional = Conocer y documentar tus límites.**